

Bloc 2

Sélection finale - hors limite des 30 pages du dossier

Pièce	Objet
B2-A20	Navigation publique, reflow, clavier et axe
B2-A25	Recette métier authentifiée et corrections
B2-A26	Playwright OAuth réel et stockage hors Git
B2-A27	Correction de l'audit des dépendances
B2-A28	Baseline main, CI, CD, OAuth et couvertures
B2-A29	Performance des healthchecks de production
B2-A30	Prototype final desktop/mobile et axe privé
B2-A31	Couverture autonome du package shared
B2-A34	Recettes métier finales et parcours journalisé
B2-A35	Recettes sécurité finales OWASP et navigateur
B2-A36	Audit accessibilité final public et privé

Les pièces historiques restent dans le dépôt mais ne sont pas présentées comme preuves de la baseline finale.

Sommaire

B2-A20 - Recette navigateur et accessibilité publique du 2026-07-20	3
B2-A25 - Recette authentifiée de production et correctifs	5
B2-A26 - Playwright authentifié avec une session OAuth réelle	7
B2-A27 - Correction de nouveaux avis de sécurité des dépendances	9
B2-A28 - Validation de la baseline main, CI, CD et OAuth	10
B2-A29 - Mesure de performance des healthchecks de production	11
B2-A30 - Prototype authentifié desktop et mobile	12
B2-A31 - Couverture autonome du package shared	15
B2-A34 - Recettes métier finales - 2026-07-21	16
B2-A35 - Recettes de sécurité finales du 21 juillet 2026	20
B2-A36 - Audit accessibilité final public et authentifié	25

B2-A20 - Recette navigateur et accessibilité publique du 2026-07-20

Compétences : C2.2.3 et C2.3.1

Version observée : 69b21ef-dirty, candidate locale 0.13.0-rc.1

Environnement : Windows, Node.js v24.14.0, Playwright 1.59.1

Périmètre réellement exécuté

Les contrôles ont été exécutés dans les navigateurs Playwright Chromium et Firefox. Le navigateur intégré Codex n'était pas disponible dans cette session (aucun navigateur détecté) : aucune inspection via ce navigateur n'est donc revendiquée.

Commandes finales réussies :

```
pnpm exec playwright test tests/e2e/browser-evidence.spec.ts --project=chromium --reporter=list
12 passed (43.1s)
```

```
pnpm exec playwright test tests/e2e/browser-evidence.spec.ts --project=firefox --reporter=list
12 passed (56.6s)
```

Une tentative ciblée supplémentaire sur /dashboard a expiré sans sortie pendant un conflit de build. Elle n'est ni conservée dans le test final ni comptée dans les 24 résultats ci-dessus.

Résultats observés

Pages publiques à 320 × 720 px

Route	HTTP	Largeur document Chromium/Firefox	Erreurs JS	Violations axe ciblées	Capture
/	200	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox
/login	200	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox
/confidentialite	200	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox
/cette-page-nexi ste-pas	404 attendu	320 / 320 px	0 / 0	0 / 0	PNG Chromium + Firefox

axe-core a été exécuté avec les tags wcag2a, wcag2aa, wcag21a et wcag21aa. Ce résultat automatisé ne constitue pas un audit RGAA manuel.

Chromium a journalisé une erreur console réseau pour la navigation HTTP 404 : Failed to load resource: the server responded with a status of 404 (Not Found). Firefox n'a pas émis ce message. Les deux JSON bruts conservent cette différence. Aucune pageerror JavaScript n'a été observée.

Clavier et focus

- sur /, /login et /confidentialite, la première touche Tab a focalisé le lien « Aller au contenu principal » dont la cible observée est #main-content ;
- après Entrée, l'élément actif observé est MAIN#main-content dans les deux navigateurs ; Chromium conserve le fragment dans l'URL, Firefox non ;
- le bouton de connexion a été focalisé et son nom accessible vérifié comme « Continuer avec Google » dans les deux navigateurs ;
- le fournisseur OAuth n'a pas été ouvert et aucune connexion n'a été tentée.

Protection sans session

Les routes /generate, /programs, /workouts et /settings ont réellement abouti à `http://localhost:3000/login` avec le titre de connexion attendu, dans Chromium et Firefox. /dashboard reste non exécuté dans cette annexe.

Anomalies détectées et corrections

1. Le lien d'évitement modifiait le fragment sans focaliser systématiquement le contenu. Correction : `tabIndex=-1` sur `main#main-content`.
 2. La lettre décorative « G » était incluse dans le nom accessible du bouton Google. Correction : `aria-hidden="true"` sur ce décor.
 3. L'inspection des captures à 320 px a révélé un contraste visuellement faible sur la page de connexion et le pied de page. Correction : panneau sombre sur la zone de connexion et textes de pied de page assombris. Une mesure manuelle des ratios reste à effectuer avant de conclure sur le critère RGAA.
- Après ces corrections, les runs finaux séparés Chromium et Firefox sont ceux indiqués plus haut. Le typage Web et le lint Web ont également réussi.

Artefacts bruts

Le dossier `browser-evidence-2026-07-20/` contient 32 fichiers :

- 8 captures PNG, quatre routes dans deux navigateurs ;
- 8 JSON de page avec URL, statut HTTP, viewport, largeur, console, `pageerror` et violations axe ;
- 6 JSON clavier ;
- 2 JSON sur le bouton Google ;
- 8 JSON de redirection sans session.

Non exécuté - ne pas présenter comme preuve

- OAuth Google réel, création de session et déconnexion ;
- pages et composants authentifiés ;
- audit manuel RGAA complet, zoom 200/400 %, lecteur d'écran et technologies d'assistance ;
- mesure manuelle de tous les contrastes ;
- /dashboard dans cette recette instrumentée ;
- production et SHA final immuable.

B2-A25 - Recette authentifiée de production et correctifs

Date : 2026-07-20

Environnement : production Vercel/Neon

Navigateur : navigateur intégré Codex, session Google ouverte par le candidat

Versions observées : 0.13.0-rc.2, puis 0.13.0-rc.3

Périmètre et méthode

Le candidat a terminé lui-même la connexion Google, puis a indiqué que la session était disponible. La recette a été conduite dans cet onglet existant, sans lire ni exporter les cookies, le stockage local ou l'identité du compte. Les observations proviennent de l'arbre d'accessibilité, de l'URL, du focus actif et des journaux console du navigateur.

Cette annexe ne vaut pas audit RGAA humain complet et ne transforme pas les contrôles automatisés en preuve manuelle.

Recette métier initiale sur 0.13.0-rc.2

Parcours	Données et actions réellement exécutées	Résultat observé
Session	ouverture de /generate après connexion réalisée par le candidat	formulaire privé affiché, navigation privée et bouton de déconnexion présents
Validation séance	soumission vide	deux alertes anglaises String must contain at least 1 character(s)
Séance IA	sport Mobilite - recette RNCP, durée 15 min, objectif et contraintes explicitement marqués comme données de recette	séance créée sous l'ID 2a4d598f-48a7-4068-8219-49ac6660adaa, détail totalisant exactement 15 min
Timer séance	démarrage, attente, pause, attente 2,2 s, reprise, Échap	décompte actif, valeurs inchangées pendant la pause, reprise correcte ; après Échap le focus tombait sur BODY
Filtre séances	inspection du filtre Sport	liste fermée à huit sports alors que la génération accepte un texte libre
Programme IA	même sport de recette, 2 semaines, 2 séances/semaine, 20 min/séance	programme créé sous l'ID e1fdc5af-84fc-4114-8af6-046daadd5f0d, 2 semaines et 4 séances de 20 min
Onglets programme	ArrowRight, Home, End	sélection et focus conformes sur les deux semaines
Séance programme	ouverture de la séance 2-1	détail de 20 min et Timer affichés
Dashboard	lecture des statistiques du compte	données réelles affichées ; variantes Course a pied et Course à pied séparées
Paramètres	lecture puis enregistrement sans changement	fournisseur OpenAI serveur, modèle GPT-5.4 mini, confirmation de sauvegarde
Suppressions	Échap sur la confirmation puis confirmation effective	focus restauré après Échap ; seules les deux ressources de recette ci-dessus ont été supprimées

Aucune erreur console n'a été observée sur ces parcours. Après le nettoyage, la liste comptait de nouveau 12 séances et 4 programmes. Aucune autre donnée du compte n'a été supprimée.

Anomalies issues de cette exécution

ID	Anomalie réelle	Correction
B2-BUG-023	messages Zod anglais dans les deux formulaires français	messages explicites français dans les schémas partagés et HTTP
B2-BUG-024	focus perdu après sortie du plein écran Timer	restauration vers le contrôle Timer vivant après démontage du portail
B2-BUG-025	filtre Sport incompatible avec les sports libres	champ de recherche texte, formulaire GET et requête conservée
B2-BUG-026	variantes typographiques comptées séparément au dashboard	regroupement casse, accents et espaces avant tri et limite

La correction a été livrée par la PR [#34](#), fusionnée dans le SHA applicatif 3a21e3b2b547e99410388d5b83b62df79a436ea8.

Vérifications de 0.13.0-rc.3

Contrôle	Preuve	Résultat
Local	pnpm test, typecheck, lint, build, audit low	155 tests API et 43 tests Web réussis ; aucune vulnérabilité connue
CI de PR	run 29746856421	6 jobs réussis, couvertures, PostgreSQL, E2E public/axe et Docker inclus
CI main	run 29747228594	6 jobs réussis sur le SHA fusionné
CD	run 29747592571	migration, API, Web et smoke tests réussis
Healthchecks	API /health, /health/ready, Web /api/health	HTTP 200, version 0.13.0-rc.3, DB ok, configuration IA ok
Monitoring	run 29748032763	succès et artefact de monitoring produit
Validation séance vide	soumission réelle de /generate	Le sport ne peut pas être vide et L'objectif ne peut pas être vide
Validation programme vide	soumission réelle de /programs/generate	mêmes alertes françaises adaptées aux champs
Filtre libre	valeur Mobilite - recette RNCP, bouton Filtrer	URL ?sport=Mobilite+-+recette+RNCP&level=, valeur conservée, état Aucun resultat
Agrégation dashboard	lecture après déploiement	une entrée Course à pied à 2 au lieu de deux variantes à 1
Focus Timer	démarrage d'une séance existante puis Échap	élément actif BUTTON, texte Pause, aria-pressed=true, dialogue fermé
Déconnexion	bouton de déconnexion puis ouverture de /dashboard	redirection finale vers /login, lien Se connecter, aucun bouton de déconnexion

Aucun journal console n'a été observé durant la contre-recette rc.3.

Limites conservées

- les écrans Google de consentement n'ont pas été instrumentés : seule la session obtenue par le candidat et son fonctionnement ont été observés ;
- aucun cookie, token ou stockage de session n'a été inspecté ;
- il ne s'agit pas d'une suite Playwright authentifiée réutilisable avec storageState ;
- le lecteur d'écran, le zoom 200/400 %, les ratios de contraste exhaustifs et la recette mobile authentifiée restent à exécuter.

B2-A26 - Playwright authentifié avec une session OAuth réelle

Date : 2026-07-21

Environnement testé : `https://ai-sport-web.vercel.app`

Commit applicatif testé : `d149076e32b6e48c1bd0811060a5ad726451ed83`

Compétences : C2.2.1, C2.2.2, C2.2.3, C2.3.1 et C2.3.2

Objet de la preuve

Cette annexe ferme l'écart « suite Playwright authentifiée avec un `storageState` réel » relevé dans B2-A25. Elle ne repose ni sur une fixture vide, ni sur un cookie fabriqué, ni sur une interception de la route de session.

Le candidat a configuré une adresse comme identité du compte Google de test et a réalisé lui-même l'étape Google OAuth dans un Chrome système ouvert avec un profil temporaire. Le script a ensuite :

1. interrogé réellement `/api/auth/session` ;
2. refusé la capture si l'adresse `Auth.js` différait de l'identité attendue ;
3. conservé uniquement les cookies et origines du domaine exact `ai-sport-web.vercel.app` ;
4. vérifié la présence d'un cookie de session `Auth.js` ;
5. protégé le fichier local par ACL NTFS limitée à l'utilisateur courant ;
6. fermé Chrome et supprimé le profil temporaire.

L'adresse du compte et le contenu du `storageState` ne figurent pas dans Git. L'état local est sous `apps/web/playwright/.auth/`, chemin ignoré par `.gitignore`. Les trois cookies conservés appartenaient au seul domaine Alcide ; aucun cookie Google n'a été écrit dans le fichier.

Anomalies réellement détectées

Le premier workflow lancé sur main, run [29814300540](#), a restauré et utilisé la vraie session mais a terminé en échec : deux assertions anciennes ciblaient un champ interne caché et l'annonceur de route `Next.js` au lieu des éléments fonctionnels attendus.

Ces faux contrôles ont été remplacés par :

- l'inspection des champs visibles du formulaire nommé, après attente de son affichage ;
- des assertions sur les alertes de champ réelles, leur visibilité et leur message français.

Le filtrage du `storageState` possède aussi un test comportemental : un cookie Alcide est conservé, tandis qu'un cookie Google et un sous-domaine trompeur sont rejetés.

Résultats obtenus

Exécution locale contre la production

Commande :

```
pnpm test:e2e:authenticated
```

Résultat observé le 2026-07-21 après la correction des dépendances : **4 tests réussis sur 4** en 13,4 s. Chaque scénario vérifie d'abord que `/api/auth/session` retourne exactement l'identité configurée.

Les contrôles qualité exécutés avant publication ont aussi réussi :

- lint sans erreur ni avertissement ESLint ;
- typecheck des workspaces réussi ;

- 155 tests API et 43 tests Web réussis ;
- 3 tests de politique de session réussis.

GitHub Actions avec GitHub Secrets

- Workflow : E2E authentifié - compte Google dédié
- Run : [29816721099](#)
- Job : Parcours authentifié sans session personnelle
- Commit : d149076e32b6e48c1bd0811060a5ad726451ed83
- Conclusion : **success**

Faits visibles dans le journal du run :

- les secrets E2E_AUTH_EMAIL et E2E_AUTH_STORAGE_B64 sont présents ;
- l'identité est masquée par GitHub dans la sortie ;
- la session est restaurée dans un fichier hors suivi Git ;
- Running 4 tests using 1 worker puis 4 passed (5.5s) ;
- l'étape de suppression de la session du runner réussit ;
- le job complet réussit en 51 s.

Limites conservées

- Le caractère exclusivement dédié du compte relève de la gouvernance du candidat ; le contrôle technique prouve l'identité configurée, pas les usages passés du compte Google.
- La connexion sur les écrans Google reste manuelle, Google refusant le navigateur directement automatisé ; Playwright intervient après le retour OAuth sur Alcide.
- Le workflow couvre quatre scénarios sur /generate. Il ne constitue pas un audit RGAA humain, un test mobile authentifié ou une recette exhaustive de toutes les routes privées.
- La session Auth.js expire et doit alors être recapturée puis remplacée dans GitHub Secrets. Aucun mot de passe Google n'est stocké par le projet.

B2-A27 - Correction de nouveaux avis de sécurité des dépendances

Date : 2026-07-21

Commit testé : d149076e32b6e48c1bd0811060a5ad726451ed83

Compétences : C2.1.2, C2.2.3 et C2.3.2

Anomalie détectée

Le run CI [29815728217](#) a échoué dans le job Security audit avec quatre vulnérabilités high :

- trois branches de brace-expansion, avis

[GHSA-3jxr-9vmj-r5cp](#) ;

- shell-quote 1.8.4, avis

[GHSA-395f-4hp3-45gv](#).

Ces avis de déni de service ont été publiés dans la base GitHub Advisory le 2026-07-20. Ils n'étaient donc pas couverts par la preuve historique B2-A23. Aucune exploitation n'a été observée ; l'échec provient du contrôle bloquant `pnpm audit --audit-level=low`.

Correction appliquée

Les overrides transitifs ont été limités aux plages vulnérables et remplacés par les premières versions publiées corrigées :

Dépendance	Versions corrigées utilisées	Dépendances parentes observées
brace-expansion	1.1.16, 2.1.2 et 5.0.7	minimatch 3, 9 et 10
shell-quote	1.9.0	concurrently et gel/drizzle-orm

La version 1.8.5 de shell-quote, initialement mentionnée par la sortie d'audit comme borne corrigée, n'existe pas dans le registre npm. Elle n'a pas été inventée ni ajoutée au lockfile : la première version corrigée publiée selon l'avis GitHub est 1.9.0.

Vérifications réelles

Les commandes locales suivantes ont réussi :

```
pnpm install --frozen-lockfile
pnpm audit --audit-level=low
pnpm exec concurrently "node --version" "node --version"
pnpm lint
pnpm typecheck
pnpm test
pnpm build
```

Résultats : aucune vulnérabilité connue, smoke concurrently réussi, 155 tests API et 43 tests Web réussis, build de production réussi.

La CI de PR [29816347653](#) a ensuite terminé avec les six jobs verts : audit de sécurité, lint/typecheck, tests et couvertures avec PostgreSQL, E2E public/accessibilité, builds des packages et images Docker.

Limite

Les avis de dépendances évoluent après chaque gel. Cette preuve décrit l'état du registre et du lockfile le 2026-07-21 ; le job bloquant doit rester actif pour détecter les avis ultérieurs.

B2-A28 - Validation de la baseline main, CI, CD et OAuth

Date : 2026-07-21

Baseline applicative finale : 0d5c6b6041333e2b756e59cb5d4440cc7ef7128b

Version annoncée par les services : 0.13.0-rc.3

Chaîne réellement exécutée

Contrôle	Exécution	Résultat
CI complète main	run 29832575391	6 jobs réussis
Migration et CD Vercel	run 29832944876	migration, API, Web et smoke tests réussis
Playwright OAuth	run 29833210488	6/6 scénarios réussis en 9,8 s
Playwright accessibilité final	exécution locale sur la production finale	33/33 sur 3 pages publiques et 5 privées
Web health	GET https://ai-sport-web.vercel.ap p/api/health	HTTP 200, status=ok
API readiness	GET https://ai-sport-api.vercel.ap p/health/ready	HTTP 200, DB ok, IA ok

La CI a exécuté lint, typecheck, tests de politiques, 170 tests API, 55 Web, 14 shared, couvertures, tests PostgreSQL, Playwright public et axe, builds de production, audit de dépendances et images Docker. Le CD n'a démarré qu'après le succès de la CI.

Artefacts de couverture détaillée du run antérieur 29817362423

Les métriques ci-dessous ont été extraites du premier run consolidé et restent conservées pour leur granularité. Le run final 29832575391 republie les quatre rapports après l'ajout des recettes finales.

Les artefacts suivants ont été listés puis téléchargés depuis GitHub Actions :

- coverage-report-api ;
- coverage-report-web ;
- coverage-report-api-integration ;
- playwright-report.

L'analyse des fichiers lcov.info donne :

Rapport	Lignes	Branches	Fonctions
API unitaire	1 038/1 212 - 85,64 %	197/245 - 80,41 %	62/65 - 95,38 %
Web	2 804/4 061 - 69,05 %	405/520 - 77,88 %	110/136 - 80,88 %
API intégration PostgreSQL	431/460 - 93,70 %	52/65 - 80 %	16/16 - 100 %

Le package shared ne disposait pas encore d'un rapport autonome dans ce run. Cette lacune est corrigée et prouvée séparément dans B2-A31.

Protection de la session OAuth

Le run authentifié restaure le storageState depuis GitHub Secrets, vérifie l'identité Auth.js attendue, n'enregistre aucune session Google et supprime le fichier du runner avant la publication du rapport. Les logs masquent l'identité. Le fichier local reste exclu de Git et protégé par les droits du seul utilisateur Windows.

Cette annexe prouve la chaîne technique observée. Elle ne prouve pas l'usage historique exclusif du compte Google ni un audit RGAA humain.

B2-A29 - Mesure de performance des healthchecks de production

Date UTC : 2026-07-21 de 09:36:34 à 09:37:07

Poste : environnement candidat Windows, réseau réel

Script : scripts/measure-production-health.mjs

Protocole

Le script a envoyé 50 requêtes séquentielles sans préchauffage et sans authentification vers chacun des trois endpoints. Une réponse n'est valide que si HTTP est réussi et si le JSON contient le statut attendu.

Objectif défini avant lecture des résultats :

- 100 % de réponses HTTP/JSON valides ;
- p95 inférieur ou égal à 1 000 ms par endpoint.

Commande :

```
node scripts/measure-production-health.mjs 50
```

Résultats bruts synthétisés

Endpoint	Succès	Minimum	Médiane	p95	Maximum	Moyenne	Objectif
Web /api/health	50/50	172,00 ms	195,12 ms	508,63 ms	552,93 ms	227,09 ms	atteint
API /health	50/50	167,91 ms	194,00 ms	339,66 ms	491,55 ms	216,42 ms	atteint
API /health/ready	50/50	169,46 ms	191,51 ms	267,11 ms	276,33 ms	199,70 ms	atteint

Total : 150 réponses valides sur 150 et trois objectifs p95 atteints.

Portée et limites

La readiness exerce réellement la connexion PostgreSQL et vérifie la présence de la configuration IA. Cette mesure ne remplace pas un test de charge, ne représente qu'un point réseau et ne mesure pas une génération OpenAI. Les erreurs fournisseur, retries et timeouts sont couverts par les tests API ; une génération réelle de production est consignée dans B2-A25 sans durée chiffrée conservée.

B2-A30 - Prototype authentifié desktop et mobile

Date : 2026-07-21
Production : <https://ai-sport-web.vercel.app>
Session : Auth.js réelle, fichier local hors Git

Méthode

Le script `apps/web/scripts/capture-rncp-prototype.mjs` ouvre Chromium avec le `storageState` Alcide déjà contrôlé, charge les formulaires privés en production et capture uniquement la zone principale. Il n'affiche ni adresse électronique ni donnée personnelle. Le profil mobile utilise un viewport de 390 x 844 px et le script échoue en cas de débordement horizontal.

La suite `apps/web/tests/e2e/generate.spec.ts` a ensuite exécuté six scénarios authentifiés sur la production :

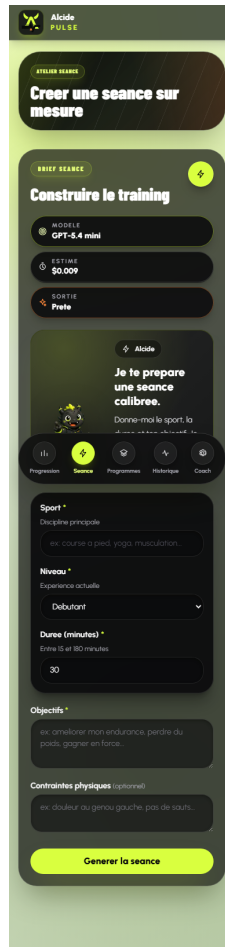
- 1. formulaire privé accessible après connexion ;
- 2. labels associés à tous les champs ;
- 3. erreur explicite sur le sport vide ;
- 4. erreurs de formulaire annoncées avec `role=alert` ;
- 5. utilisation à 390 px sans débordement horizontal ;
- 6. aucune violation axe critique ou sérieuse sur le formulaire privé.

Résultat local : 6/6 en 15,7 s.

Le workflow distant a ensuite exécuté la même suite sur le commit `81b2b0bd6afa0cf3a33cca6d7ee045ae5808709d` : run GitHub Actions [29820498452](#), 6/6 en succès. La session dédiée a été restaurée depuis GitHub Secrets, utilisée uniquement pour le domaine Alcide, puis supprimée du runner.

Captures et empreintes

Capture	Dimensions	SHA-256
génération séance desktop	1440 x 992	A2E6530CA4E189359641F1CA611A4F99A7D0C3F6010E629FC0B81F9AB239443C
génération programme desktop	1440 x 1101	2CB08B244579FCB3546173E10459536819268E43943E8122957E4336F7FD6E97
génération séance mobile	390 x 1634	481517A35F7AD80E0A7B186681A88790F8372CFC046DA5D61AB68002532E79BC



Génération d'une séance à 390 px

Limite

Le contrôle mobile et axe est automatisé. Il ne remplace pas le zoom manuel, les contrastes exhaustifs ou la restitution par un lecteur d'écran.

B2-A31 - Couverture autonome du package shared

Date : 2026-07-21

Commit technique : 81b2b0bd6afa0cf3a33cca6d7ee045ae5808709d

CI de pull request : [run 29819423534](#)

Écart corrigé

Les contrats shared étaient exercés indirectement depuis les tests API, mais ne disposaient ni d'une suite autonome ni d'un rapport de couverture séparé. Le dossier ne pouvait donc pas chiffrer honnêtement ce périmètre.

Harnais ajouté

La suite `packages/shared/tests/schemas.test.ts` couvre :

- cohérence de la durée détaillée d'une séance ;
- bornes des formulaires séance et programme ;
- numérotation des semaines et séances ;
- nombre de semaines et de séances ;
- durée annoncée et durée détaillée des programmes ;
- références autorisées pour un journal de séance simple ou de programme.

Commande :

```
pnpm --filter shared test:coverage
```

Résultat local et CI

Indicateur	Résultat
Fichiers de test	1/1 réussi
Tests	14/14 réussis
Statements	100 %
Lignes	100 %
Fonctions	100 %
Branches	92,85 %

Le job `Unit tests and coverage` du run 29819423534 a réussi et a publié l'artefact `coverage-report-shared`. La CI continue de publier séparément les rapports API, Web et PostgreSQL ; les taux ne sont pas fusionnés artificiellement.

Les fichiers de types TypeScript sans code runtime sont compilés par `tsc` et ne sont pas inclus dans le taux V8 des schémas exécutables.

B2-A34 - Recettes métier finales - 2026-07-21

Compétence : C2.3.1 - cahier de recettes.

Exécution : 21 juillet 2026, de 14 h 23 à 14 h 40 (Europe/Paris).

Révision de départ : bac3b916770cabbbc92e3cda0d58ac3ed7e5e119.

État testé : copie de travail contenant les correctifs décrits ci-dessous ; les

contrôles de production portent encore sur la version Vercel déployée au moment du test.

Gel final : correctifs fusionnés par la PR 43 dans

0d5c6b6041333e2b756e59cb5d4440cc7ef7128b, puis CI 29832575391, CD

29832944876 et E2E OAuth 29833210488 réussis.

1. Environnements et données

Couche	Environnement réellement utilisé
API/Web local	Windows, Node 24.14.0, pnpm 11.9.0, Vitest et build Next.js
PostgreSQL	conteneur local postgres:16-alpine, base de test sur localhost:5432
Parcours authentifié	https://ai-sport-web.vercel.app, Chromium Desktop Chrome, session OAuth réelle dédiée et non versionnée
Identité	l'adresse du compte de recette a été dérivée de /api/auth/session pour vérifier la session, sans être imprimée dans les sorties

Les tests PostgreSQL créent deux comptes aléatoires et les suppriment en fin de suite. Le parcours de production utilise uniquement le compte OAuth de recette.

2. Anomalies corrigées pendant la recette

CR-038 - modèle OpenAI non autorisé accepté

L'API acceptait toute chaîne commençant par gpt-, alors que l'interface ne propose que trois modèles. Un appel direct pouvait donc persister une valeur non autorisée.

Correctif dans apps/api/src/controllers/settings.controller.ts :

- liste fermée gpt-5.4-mini, gpt-5.4, gpt-5.5 ;
- validation Zod avant tout appel au repository ;
- repli sur gpt-5.4-mini à la lecture d'une ancienne valeur inconnue ;
- test HTTP : réponse 400 BAD_REQUEST et zéro appel à upsertSettings.

CR-030/CR-034 - revalidation de la page courante après journalisation

Une tentative de production a montré que la revalidation de la page Timer pouvait remonter le composant avant que la confirmation de sauvegarde reste visible. La séance et le programme ne changent pas lors de la création d'un journal ; seule la donnée du dashboard doit être invalidée.

Correctif dans les deux pages de séance :

- conservation de revalidatePath('/dashboard') ;
- suppression de la revalidation de la page Timer courante ;
- conservation de la revalidation de la fiche programme parente pour une séance issue d'un programme.

3. Résultats par scénario

ID	Exécution et preuve	Résultat
CR-013	simulations OpenAI 429, 503 et timeout de 45 000 ms ; test HTTP 503, absence d'appel à createWorkout ; test UI du message et de la réutilisation du formulaire	Réussi sur la candidate par simulation déterministe
CR-018	page 2/2 rendue côté Web ; paramètres page=2, limit=1 et user Id transmis ; PostgreSQL réel avec trois programmes du propriétaire et un programme d'un autre compte	Réussi, pagination et isolation confirmées
CR-021	suppression programme en erreur 500 ; message conservé par l'API et confirmation UI maintenue ouverte avec alerte	Réussi
CR-030	création HTTP d'un journal avec durée active 487 s ; PostgreSQL réel ; parcours production Timer puis enregistrement	Réussi
CR-034	note facultative normalisée puis stockée sous l'identité authentifiée ; page Confidentialité vérifiée ; note de recette saisie en production	Réussi
CR-035	annulation, Échap, restauration du focus et panne API testés pour une séance ; confirmation maintenue ouverte	Réussi
CR-037	changement local autorisé ; en production, changement, rechargement et lecture de la valeur persistée, puis restauration de la valeur initiale dans un bloc finally	Réussi, aucun réglage temporaire laissé
CR-038	valeur gpt - modele - interdit envoyée à l'API locale candidate	Réussi : 400, aucune persistance
CR-040	dashboard rendu avec zéro séance et zéro journal	Réussi : état « Aucune activité encore », explication et CTA /generate
CR-041	rendu de totaux connus (4, 3, 1 h 30, effort 6.5/10), agrégation sport ; PostgreSQL réel isolé ; production après journalisation	Réussi
CR-065	session OAuth validée, page Programmes ouverte, séance existante ouverte, toutes les phases Timer passées, effort/feedback/note saisis, journal sauvegardé puis dashboard relu	Réussi : compteur « Terminé » de 3 à 4

4. Commandes et sorties conservées

Les commandes ci-dessous ont été lancées avec le runtime Node fourni par l'espace de travail. Aucun secret ni cookie n'a été affiché.

Tests ciblés métier

```
pnpm --filter api exec vitest run \
  tests/rncp-ai-unavailability-recipes.test.ts \
  tests/rncp-business-recipes.test.ts
```

```
Test Files 2 passed (2)
Tests      9 passed (9)
```

```
pnpm --filter web exec vitest run components/rncp-business-recipes.test.tsx
```

```
Test Files 1 passed (1)
Tests      9 passed (9)
```

Suites complètes et PostgreSQL

```
pnpm --filter api test
```

```
Test Files 19 passed (19)
Tests      170 passed (170)
```

```
pnpm --filter web test
```

```
Test Files 14 passed (14)
```

```
Tests          55 passed (55)
$env:TEST_DATABASE_URL='postgresql://alcide:alcide_dev@localhost:5432/alcide'
pnpm --filter api test:integration

Test Files     1 passed (1)
Tests          8 passed (8)
```

Cette suite PostgreSQL contient notamment : pagination et suppression des programmes sans exposition inter-compte, journalisation d'une source détenue, stockage de painNotes, statistiques exactes et statistiques vides pour l'autre compte.

Qualité et compilation

```
pnpm typecheck
packages/shared: Done
apps/api: Done
apps/web: Done

pnpm lint
apps/api: Done
apps/web: No ESLint warnings or errors

pnpm build
shared: tsc réussi
api: tsc réussi
web: Next.js - Compiled successfully, 13/13 pages générées
```

Production authentifiée

Commande assainie :

```
PLAYWRIGHT_AUTH_STORAGE=<fichier local ignoré par Git>
E2E_AUTH_EMAIL=<valeur dérivée de la session, non affichée>
E2E_BASE_URL=https://ai-sport-web.vercel.app
pnpm --filter web exec playwright test \
  --config=playwright.rncp-recipes.config.ts
```

Résultats utiles :

```
CR-037 : passed (4.6 s), modèle initial restauré
CR-030/034/041/065 : passed (14.5 s)
[RNCP CR-065] dashboard 3 -> 4; formulaire=confirmation-visible
```

5. Traçabilité honnête des tentatives

Trois exécutions du parcours authentifié ont eu lieu :

1. la première s'est arrêtée avant l'envoi du journal, car le clic Playwright visait l'input radio visuellement masqué ; aucune donnée n'a été créée par cette tentative ;
2. la deuxième a atteint l'envoi, puis l'assertion a échoué parce que `getByRole('status')` correspondait à trois éléments. Elle a pu créer un journal, mais l'incrément du dashboard n'a pas été mesuré pendant cette tentative ;
3. la dernière exécution a mesuré explicitement 3 -> 4 et constitue la preuve de clôture retenue.

Il n'existe pas d'interface de suppression des journaux. Le journal final - et éventuellement celui de la deuxième tentative - reste donc dans le compte de recette. Les champs contiennent uniquement les marqueurs de test suivants :

- douleur:Recette RNCP : gene legere temporaire, donnee de test.;
- notes:Parcours final automatise du 2026-07-21..

6. Limites

- CR-013 a été couvert par simulations reproductibles 429, 503 et timeout ; aucune panne réelle d'OpenAI n'a été provoquée en production.
- CR-018 et l'isolation multi-compte de CR-041 ont été exécutés sur PostgreSQL local réel, pas avec deux comptes OAuth de production.

- CR-040 est une recette de rendu déterministe avec données vides simulées ; le compte de production n'est plus vide.
- CR-065 valide une session OAuth existante et visite les objets déjà présents ; il ne rejoue pas l'écran Google ni une nouvelle génération OpenAI.
- Le verrouillage CR-038 et les suppressions de revalidation sont validés dans la copie de travail et le build local. Ils devront être déployés avant d'affirmer qu'ils sont présents sur la production.

7. Pièces techniques

- apps/api/tests/rncp-ai-unavailability-recipes.test.ts
- apps/api/tests/rncp-business-recipes.test.ts
- apps/web/components/rncp-business-recipes.test.tsx
- apps/web/tests/e2e/rncp-recipes-final.spec.ts
- apps/web/playwright.rncp-recipes.config.ts
- apps/api/src/controllers/settings.controller.ts
- apps/web/app/workouts/[id]/page.tsx
- apps/web/app/programs/[id]/sessions/[sessionId]/page.tsx

Conclusion : les onze scénarios du lot métier disposent maintenant d'une preuve exécutée. Les limites de production ci-dessus ne sont pas converties en preuves plus fortes qu'elles ne le sont.

B2-A35 - Recettes de sécurité finales du 21 juillet 2026

Objet et conclusion

Cette annexe consigne la fermeture non destructive des recettes de sécurité CR-042, CR-043, CR-045, CR-046 et CR-047. Elle complète la revue OWASP pour les catégories A02, A03, A04, A05 et A09.

Les contrôles automatisés et les observations de production sont concluants :

- 6/6 tests API en mémoire et 1/1 test d'intégration PostgreSQL réussis ;
- 1/1 test de rendu React hostile réussi ;
- 6/6 tests Playwright réussis dans Chromium et Firefox, puis 3/3 Chromium

après le durcissement de la collecte des ressources ;

- 0 vulnérabilité connue retournée par `pnpm audit --audit-level low` ;
- 0 sink DOM dangereux, 0 appel DB non paramétré recherché et 0 clé OpenAI

longue dans les fichiers suivis ;

- production Web et API disponibles en HTTPS ;
- CORS de production refusé à une origine hostile et accordé uniquement au

front officiel ;

- 0 occurrence des marqueurs de secrets recherchés dans le HTML et les neuf

scripts JavaScript chargés par la page de production.

Aucun défaut applicatif nécessitant un correctif de production n'a été trouvé pendant cette campagne. Les ajouts sont des tests de non-régression et la présente preuve. Le risque résiduel principal est la présence de `'unsafe-inline'` dans `script-src` et `style-src` ; `'unsafe-eval'` est bien absent de la CSP de production.

Périmètre et environnement

Élément	Valeur contrôlée
Date et heure de fin des observations	2026-07-21, 14:26 CEST / 12:26 UTC
Révision de base locale	bac3b916770cabbbc92e3cda0d58ac3ed7e5e119 (main)
Gel applicatif final	0d5c6b6041333e2b756e59cb5d4440cc7ef7128b, CI/CD réussies
État local	révision de base avec tests et documents RNCP non commités
Système	Windows NT 10.0.22631
Node.js	24.14.0
pnpm	11.9.0
Vitest	3.2.6
Playwright	1.59.1
Navigateurs	Chromium et Firefox fournis par Playwright
PostgreSQL local	16.14 dans le conteneur alcide-db
Web local	Next.js démarré automatiquement sur <code>http://localhost:3000</code>
Web officiel observé	<code>https://ai-sport-web.vercel.app</code>
API officielle observée	<code>https://ai-sport-api.vercel.app</code>

Les tests API de CORS, headers et refus d'authentification utilisent l'instance Hono en mémoire. Le test CR-042 distinct utilise PostgreSQL local, crée un utilisateur jetable, insère et relit la charge via le repository, vérifie la table puis supprime l'utilisateur par cascade. Aucun test n'appelle OpenAI ou OAuth. Les requêtes de production sont uniquement des GET, HEAD ou pré-requêtes OPTIONS.

Résultat par scénario

ID	Contrôle exécuté	Résultat observé	Statut
CR-042	Compilation du prédicat Drizzle avec <code>' ; DROP TABLE workouts; --</code>	la requête contient un placeholder \$1, le texte n'apparaît pas dans le SQL et reste dans params	Fermé
CR-042	Insertion et relecture via le repository sur PostgreSQL 16.14	la chaîne exacte est relue dans la colonne et le JSONB ; workouts reste requêteable ; nettoyage vérifié à 0 utilisateur de test	Fermé
CR-042	Validation HTTP Zod avec chaînes SQL-like et dépassement de borne	la chaîne bornée reste une donnée ; un objectif de 501 caractères est rejeté	Fermé
CR-043	Rendu d'un titre <code><script></code> et d'un sport <code></code> dans WorkoutCard	texte visible mais aucun nœud script ou image hostile, aucun attribut d'exécution modifié	Fermé
CR-043	Payload XSS contrôlé dans l'URL, Chromium et Firefox	aucune exécution et aucune réflexion brute dans le HTML	Fermé
CR-045	Inspection HTML et scripts dans deux navigateurs locaux	aucun nom ou valeur sentinelle de secret, aucun motif de clé sk- * longue	Fermé
CR-045	Inspection de la production officielle	HTML de 54 578 caractères et 9 scripts ; 0 OPENAI_API_KEY, SERVICE_SECRET, AUTH_SECRET, AUTH_GOOGLE_SECRET et clé sk- * longue	Fermé
CR-046	Pré-requête locale avec Origin: <code>https://hostile.rncp.test</code>	HTTP 204 sans Access-Control-Allow-Origin	Fermé
CR-046	Pré-requête de production avec une origine hostile	HTTP 204 sans Access-Control-Allow-Origin	Fermé
CR-046	Pré-requête de production avec le front officiel	HTTP 204 avec Access-Control-Allow-Origin: <code>https://ai-sport-web.vercel.app</code>	Fermé
CR-047	Headers effectifs dans Chromium et Firefox	CSP, nosniff, DENY, referrer policy et permissions policy présents	Fermé
CR-047	Headers du Web de production	HSTS, CSP complète, nosniff, DENY, referrer policy et permissions policy présents ; 'unsafe-eval' absent	Fermé avec risque résiduel documenté

Détail des contrôles OWASP

A02 - Défaillances cryptographiques

- Les URL HTTP du Web et de l'API répondent 308 Permanent Redirect vers HTTPS.
- Le Web retourne ``Strict-Transport-Security: max-age=63072000; includeSubDomains; preload``.
- L'API retourne ``Strict-Transport-Security: max-age=15552000; includeSubDomains``.
- Le navigateur ne reçoit aucun des marqueurs de secrets serveur recherchés.
- Le module d'appel API reste importé avec `server-only` et injecte le secret interservice uniquement côté serveur.

A03 - Injection

Le test compile le même prédicat `eq(workouts.sport, valeur)` utilisé par les repositories. Même avec la charge textuelle `' ; DROP TABLE workouts; --`, le texte reste dans le tableau des paramètres et n'est pas concaténé au SQL. Une recherche complémentaire ne trouve ni `sql.raw()` ni `db.execute()` dans `apps/api/src`, et aucun usage de `dangerouslySetInnerHTML`, affectation à `innerHTML`, `eval()` ou `new Function()` dans le code applicatif.

La charge exacte a ensuite été envoyée au PostgreSQL local uniquement comme paramètre du repository Drizzle. Elle a été relue sans altération dans la colonne `sport` et le JSONB. Une requête `SELECT` exécutée après l'insertion a confirmé que `workouts` restait utilisable. Le nettoyage par suppression de l'utilisateur de test a laissé 0 utilisateur `rnnp-security-*` et 0 séance dans cette base locale. Aucune requête de suppression issue de la charge n'a été exécutée et la production Neon n'a pas été modifiée.

A04 - Conception non sécurisée

- Zod revalide les données au contrôleur HTTP, indépendamment de la validation du formulaire Web.
- Les limites sont vérifiées : la charge SQL-like bornée est une donnée valide, tandis qu'un champ dépassant 500 caractères est rejeté.
- Les tests n'appellent aucun fournisseur externe et n'augmentent aucune charge de production.
- Le refus d'accès aux routes privées reste effectué avant tout accès à la base lorsque le secret interservice est invalide.

A05 - Mauvaise configuration de sécurité

Le Web de production retourne notamment :

```
Content-Security-Policy: default-src 'self';
script-src 'self' 'unsafe-inline';
style-src 'self' 'unsafe-inline';
img-src 'self' data: https;;
font-src 'self';
connect-src 'self' https://ai-sport-api.vercel.app;
object-src 'none'; base-uri 'self'; form-action 'self';
frame-ancestors 'none'; upgrade-insecure-requests
X-Content-Type-Options: nosniff
X-Frame-Options: DENY
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=()
```

L'API de production ajoute entre autres `Cross-Origin-Opener-Policy: same-origin`, `Cross-Origin-Resource-Policy: same-origin, nosniff`, `HSTS` et `Cache-Control: no-store, max-age=0` sur `/health`.

A09 - Journalisation et surveillance

Le test d'accès privé avec un secret contrôlé invalide obtient HTTP 401. Le serveur émet l'événement `[Auth] Secret interne invalide` ou manquant avec le chemin `/workouts`. Le corps client contient uniquement l'erreur générique `UNAUTHORIZED` et n'expose ni la valeur envoyée, ni le secret attendu, ni une stack trace.

Cette preuve porte sur la génération et la séparation serveur/client des logs. Elle ne revendique pas une plateforme centralisée de corrélation, d'alerte et de rétention des journaux.

Commandes reproductibles et sorties synthétiques

Tests API et rendu React

```
pnpm --filter api exec vitest run tests/rncp-security-final.test.ts
## 1 fichier réussi ; 6 tests réussis

docker start alcide-db
$env:TEST_DATABASE_URL = `
  'postgresql://alcide:alcide_dev@127.0.0.1:5432/alcide'
pnpm --filter api exec vitest run --config vitest.rncp-security.config.ts
## 1 fichier réussi ; 1 test PostgreSQL réussi (4.39s)
docker exec alcide-db psql -U alcide -d alcide -tAc `
  "select count(*) from users where email like 'rncp-security-%@alcide.test';"
## 0
docker exec alcide-db psql -U alcide -d alcide -tAc `
  "select count(*) from workouts;"
## 0 dans cette base locale après cleanup
docker stop alcide-db

pnpm --filter web exec vitest run components/rncp-security-final.test.tsx
## 1 fichier réussi ; 1 test réussi
```

L'avertissement indiquant que OPENAI_API_KEY est absente est attendu dans le test API : aucune route de génération n'est appelée.

Tests navigateur

```
pnpm --filter web exec playwright test tests/e2e/rncp-security-final.spec.ts
## Running 6 tests using 2 workers
## 6 passed (48.9s)

pnpm --filter web exec playwright test `
  tests/e2e/rncp-security-final.spec.ts --project=chromium
## rejou après attente déterministe des corps de réponse : 3 passed (33.7s)
```

Les trois scénarios sont exécutés une fois sous Chromium et une fois sous Firefox : XSS URL, absence de secrets navigateur et headers/CSP effectifs.

Audit des dépendances et recherches ciblées

```
pnpm audit --audit-level low
## No known vulnerabilities found

rg -n "dangerouslySetInnerHTML|\.innerHTML\s*=\|beval\(|new Function\(" `
  apps packages --glob '!*/*.test.*' --glob '!*/.next/**' `
  --glob '!*/node_modules/**'
## aucune occurrence

rg -n "sql\.raw\(|db\.execute\(" apps/api/src --glob '*.ts'
## aucune occurrence

git grep -I -n -E "sk-[A-Za-z0-9_-]{20,}" -- . '!pnpm-lock.yaml'
## aucune occurrence
```

CORS et headers de production

```
curl.exe -sS -D - -o NUL -X OPTIONS `
  https://ai-sport-api.vercel.app/health `
  -H "Origin: https://hostile.rncp.test" `
  -H "Access-Control-Request-Method: GET"
## 204 ; aucun Access-Control-Allow-Origin

curl.exe -sS -D - -o NUL -X OPTIONS `
  https://ai-sport-api.vercel.app/health `
  -H "Origin: https://ai-sport-web.vercel.app" `
  -H "Access-Control-Request-Method: GET"
## 204 ; Access-Control-Allow-Origin: https://ai-sport-web.vercel.app

curl.exe -sS -D - -o NUL https://ai-sport-web.vercel.app/
curl.exe -sS -D - -o NUL https://ai-sport-api.vercel.app/health
## 200 pour les deux services ; headers décrits ci-dessus
```

Inspection des ressources navigateur de production

```
$base = 'https://ai-sport-web.vercel.app'
$html = (curl.exe -sS "$base/" | Out-String)
$scripts = [regex]::Matches($html, '<script[^>]+src="(["]+)"') |
    ForEach-Object { $_.Groups[1].Value } | Sort-Object -Unique
$parts = foreach ($source in $scripts) {
    $url = if ($source.StartsWith('http')) { $source } else { "$base$source" }
    curl.exe -sS $url | Out-String
}
$surface = $html + [string]::Join("`n", $parts)
## HTML_CHARS=54578 ; SCRIPT_COUNT=9
## OPENAI_API_KEY=0 ; SERVICE_SECRET=0 ; AUTH_SECRET=0
## AUTH_GOOGLE_SECRET=0 ; LONG_SK_PATTERN=0
```

Fichiers de preuve ajoutés

- apps/api/tests/rncp-security-final.test.ts ;
- apps/api/tests/rncp-security-final.integration.test.ts ;
- apps/api/vitest.rncp-security.config.ts ;
- apps/web/components/rncp-security-final.test.tsx ;
- apps/web/tests/e2e/rncp-security-final.spec.ts ;
- docs/rncp/bloc2-annexes/B2-A35-recettes-securite-finales-2026-07-21.md.

Limites et risque résiduel

1. La chaîne contenant DROP TABLE est compilée puis persistée comme donnée dans PostgreSQL local. Elle n'est jamais exécutée comme SQL et n'est pas envoyée à Neon ; la preuve ne simule donc aucune attaque sur la production.
2. Le test XSS couvre le sink React d'une carte alimentée par une valeur persistée et la non-réflexion URL dans deux vrais navigateurs. Il ne crée pas de séance en production et n'engendre aucun coût OpenAI.
3. L'inspection de secrets est une recherche déterministe de noms, valeurs sentinelles et formats de clés connus dans les ressources effectivement chargées ; elle ne remplace pas un gestionnaire de secrets ni une rotation.
4. Le refus CORS protège les navigateurs. Un client serveur n'est pas soumis à CORS ; l'authentification interservice reste donc le contrôle principal des routes privées.
5. La CSP autorise encore 'unsafe-inline' pour les scripts et styles requis par l'implémentation Next.js actuelle. Une CSP à nonce ou hash constitue un durcissement futur. En revanche, 'unsafe-eval' est absent en production, object-src vaut 'none' et frame-ancestors vaut 'none'.
6. La preuve A09 vérifie la génération d'un événement et l'absence de fuite client ; l'observabilité centralisée et les alertes restent un chantier MCO distinct.

B2-A36 - Audit accessibilite final public et authentifie

Date d'execution : 2026-07-21

Application observee : `https://ai-sport-web.vercel.app`

Source locale au debut du controle : `bac3b916770cabbbc92e3cda0d58ac3ed7e5e119`

Contre-recette après déploiement final : 33/33 sur

`0d5c6b6041333e2b756e59cb5d4440cc7ef7128b`, après CI 29832575391 et CD

29832944876.

Referentiel de travail : RGAA 4.1.2 et WCAG 2.1 A/AA

Statut : preuves renforcees, conforme RGAA exhaustive non revendiquee

Objet et perimetre

Cette campagne ferme les controles automatisables restes ouverts sur un echantillon public et prive : reflow correspondant a un zoom de 200 % et 400 %, parcours clavier, visibilite du focus, contrastes calculables, structure et annonces exposees aux technologies d'assistance.

Pages publiques testees :

- / ;
- /login ;
- /confidentialite.

Pages privees testees avec une vraie session Auth.js locale :

- /dashboard ;
- /generate ;
- /programs ;
- /workouts ;
- /settings.

Un controle navigateur authentifie independant a aussi couvert /programs/generate. Les champs hidden ajoutes par Next.js pour les Server Actions ont ete exclus des controles de labels : ils ne sont ni visibles, ni modifiables, ni atteignables au clavier.

Protection de la session

Le storageState OAuth utilise est un fichier local ignore par Git et non suivi. La configuration dediee desactive traces, captures et videos pour eviter d'enregistrer des cookies ou des donnees de compte. Le test verifie uniquement la presence d'un cookie de session Auth.js sans imprimer son nom complet, sa valeur, l'adresse electronique ou le contenu du fichier.

Methode reproductible

La suite dediee se trouve dans `apps/web/tests/e2e/rncp-accessibility-final.spec.ts` et sa configuration dans `apps/web/playwright.rncp-accessibility.config.ts`. Elle a ete executee avec Chromium et Playwright, en production, avec un worker unique :

```
$env:PLAYWRIGHT_AUTH_STORAGE='<chemin local ignore par Git>'
$env:E2E_BASE_URL='https://ai-sport-web.vercel.app'
pnpm --filter web exec playwright test --config=playwright.rncp-accessibility.config.ts
```

Les controles sont les suivants :

1. reflow a 640 pixels CSS, equivalent de mise en page d'un viewport bureau de 1280 pixels zoome a 200 % ;
2. reflow a 320 pixels CSS, equivalent de mise en page du meme viewport zoome a 400 % ;

3. parcours Tab complet de toutes les commandes visibles, jusqu'a la sortie du document, avec comparaison a l'inventaire des elements tabulables ;
4. verification de :focus-visible et d'un indicateur perceptible, par contour ou ombre de focus, a chaque etape ;
5. regle color-contrast d'axe sans filtrage par severite, completee par le calcul sRGB du ratio texte/fond du bouton principal opaque ;
6. inspection de l'arbre d'accessibilite Chromium par CDP : RootWebArea, main, navigation et au moins un titre nomme ;
7. declenchement des erreurs de /generate et controle des regions role="alert".

L'inspection CDP est une lecture de l'arbre d'accessibilite. Elle ne constitue pas un test avec un lecteur d'ecran.

Resultats Playwright

Resultat final : **33 tests reussis sur 33**, en 1 minute 6 secondes environ.

Controle	Pages	Resultat
Reflow 640 et 320 pixels CSS	3 publiques + 5 privees	8/8, aucun scrollWidth superieur au viewport
Cycle clavier complet et focus visible	3 publiques + 5 privees	8/8, aucune commande omise, aucun piege detecte
Contrastes	3 publiques + 5 privees	8/8 tests sans violation axe ; mesure representative conforme
Arbre d'accessibilite	3 publiques + 5 privees	8/8, racine, contenu principal, navigation et titre exposes
Erreurs dynamiques	/generate	erreurs de champs exposees avec role="alert"

Le controle navigateur authentifie independant a confirme l'absence de debordement horizontal sur /generate, /programs/generate, /workouts, /dashboard et /settings a 640 x 720 puis 320 x 720 pixels. Les largeurs de document relevees etaient respectivement 625 et 305 pixels, donc inferieures a la largeur utile du viewport. Aucun identifiant HTML duplique n'a ete trouve sur les etats stabilises.

Contrastes mesures

Les ratios sRGB du texte sur le fond opaque du bouton principal sont :

Pages	Ratio minimal mesure	Seuil AA texte normal
/, /login, /confidentialite	17,36:1	4,5:1
/dashboard, /generate, /programs, /workouts, /settings	8,19:1	4,5:1

Axe a mesure en plus 2 textes sur /, 3 sur /login, 1 sur /confidentialite, aucun sur le dashboard vide, 1 sur /generate, 4 sur /programs, 10 sur /workouts et 1 sur /settings. Aucune violation de la regle color-contrast n'a ete renvoyee.

Chaque page conserve toutefois **une verification axe incomplete** en raison des fonds composites, transparences ou images. Les ratios ci-dessus sont donc des mesures representatives, pas une mesure exhaustive de chaque texte, et ne suffisent pas a declarer une conformite RGAA complete.

Structure et annonces

Les huit pages de l'échantillon exposent dans l'arbre d'accessibilité une racine de document, une région principale, une navigation nommée et au moins un titre. Sur /generate, l'envoi du formulaire vide rend visibles plusieurs erreurs, dont #input-sport-error et #goals-error, chacune exposée avec role="alert".

Le contrôle indépendant a détecté deux h1 sur /generate et /programs/generate : un titre de page et un titre de formulaire. Le titre de chaque formulaire a été corrigé en h2 dans WorkoutForm.tsx et ProgramForm.tsx. Le test de non-régression components/rncp-accessibility-structure.test.tsx vérifie que les deux titres internes restent de niveau 2 et continuent de nommer leur formulaire. Résultat : **2 tests réussis sur 2**. Cette correction est vérifiée dans la source locale ; elle devra être redéployée avant d'être attribuée à la production.

Anomalies et corrections

Identifiant	Observation	Action	Etat
B2-A36-01	Deux h1 sur chacune des pages de génération	Titres internes passés en h2 et test de non-régression ajouté	Corrige dans la source, déploiement à confirmer
B2-A36-02	Axe ne peut pas calculer un contraste composite par page	Mesure sRGB du bouton opaque ajoutée ; contrôle visuel/manuel exhaustif requis	Partiellement couvert
B2-A36-03	Aucun lecteur d'écran réel utilise pendant cette campagne	Prevoir NVDA ou Narrator avec restitution documentée	Ouvert
B2-A36-04	Le reflow est simulé par viewport CSS, sans commande de zoom du navigateur	Conserver les tests 640/320 et réaliser un essai manuel Ctrl+zoom pour une preuve littérale	Partiellement couvert

Conclusion et limites

Les sous-contrôles reflow, clavier, focus visible, structure de l'arbre et annonces d'erreur sont couverts sur l'échantillon. Les contrastes opaques représentatifs respectent largement le seuil AA et aucune violation axe n'est remontée.

Le scénario d'accessibilité ne doit cependant pas être marqué entièrement clos tant que les trois points suivants ne sont pas réalisés et consignés :

- essai réel du zoom navigateur à 200 % et 400 % ;
- vérification manuelle des contrastes composites signales incomplète ;
- parcours avec un vrai lecteur d'écran, par exemple NVDA ou Narrator.

En particulier, **aucun test NVDA, Narrator, JAWS ou VoiceOver n'a été réalisé** ici. L'arbre d'accessibilité Chromium apporte une preuve structurelle utile, mais ne permet pas de conclure sur la qualité de la restitution vocale ni sur le confort d'usage réel. Le statut global reste donc « conforme RGAA non déterminée », sans revendication de conformité exhaustive.